PASSIVE RECONNAISSANCE AND INFORMATION GATHERING

Cybersecurity Practical Assignment · Module 3

Prepared by	Bilal Fairoos
Target	owasp.org (OWASP Foundation website)
Assessment type	Passive footprinting and public-information review
Collection date	16 October 2026 (as shown in terminal output)

Purpose
To document publicly observable domain, DNS, web-technology, HTTP-header, search-index, and certificate-transparency information for learning purposes. This report records observations only; it does not claim that a vulnerability was found.

Scope note

The planned work was passive reconnaissance. One Nmap SYN scan was also run experimentally against an IP returned during lookup; it is excluded from the formal findings because active scanning is outside the stated passive scope and authorization for that activity was not established in the available notes.

This report is based on the terminal outputs and screenshots shared for this assignment. Results can change over time and should be treated as a point-in-time snapshot.

1. Executive Summary

The review collected domain-registration information, DNS records, basic web-technology indicators, HTTP response headers, publicly indexed search results, and certificate-transparency records for owasp.org. The website returned HTTP 200 during the checks. DNS lookups returned A, NS, MX, and TXT data when queried successfully. WhatWeb identified Vercel and Next.js indicators, while the HTTP response included several browser security headers. A Google search surfaced a publicly indexed OWASP financial-statement document. Certificate-transparency search results displayed certificates associated with the domain and subdomains.

No vulnerability was confirmed by these passive checks. The results describe exposed public metadata and observed configuration indicators, not a full security assessment.

2. Objective and Scope

Objectives:

• Collect public domain-registration and DNS information.

• Identify visible website technology indicators using WhatWeb.

• Review HTTP response headers using a HEAD request.

• Review search-engine indexing and certificate-transparency records.

• Document actual observations, limitations, and evidence without overstating risk.

In scope: public lookups and publicly accessible response metadata. Out of scope: exploitation, login attempts, brute force, vulnerability confirmation, and active scanning. The experimental Nmap output is not treated as an in-scope finding.

3. Methodology and Tools

Tool / source	Purpose	Recorded outcome
WHOIS	Domain registration and registrar metadata	Registrar and nameserver details returned
dig	A, NS, MX, TXT and other DNS record lookups	A/NS/MX/TXT successful; initial TXT query timed out
WhatWeb	Visible web-technology identification	HTTP 200; Vercel and Next.js indicators
curl -I	Review HTTP response headers	HTTP/2 200 and multiple security-related headers
Google search	Review indexed public pages and PDFs	OWASP financial-statement document appeared
crt.sh	Review certificate-transparency entries	Certificate records and subdomain names displayed

4. Domain Registration (WHOIS)

The WHOIS output identified owasp.org and showed GoDaddy as the registrar. The output also displayed Cloudflare nameservers and domain-status information. Registration contact details were redacted in the captured result.

Interpretation: WHOIS can provide administrative and registration metadata. Registrar and nameserver information are informational and do not, by themselves, indicate a security weakness.

5. DNS Reconnaissance

5.1 A records

The DNS output returned two IPv4 addresses: `216.150.16.129` and `216.150.1.129`. WhatWeb separately reported `216.150.1.129` during its request.

These are addresses returned during the collection period. Hosting and CDN configurations can change, and an IP may serve shared infrastructure.

5.2 NS records

The nameservers returned were `west.ns.cloudflare.com` and `fay.ns.cloudflare.com`. This indicates that Cloudflare nameservers were listed for the domain at the time of the query.

5.3 MX records

The MX response listed Google mail servers, including `aspmx.l.google.com` and `alt*.aspmx.l.google.com` entries.

5.4 TXT records

A query to the default resolver initially timed out. A subsequent query to Cloudflare DNS using `dig @1.1.1.1 TXT owasp.org` succeeded with status NOERROR, 10 TXT answers, and a reported query time of 56 ms. The returned records included Microsoft, Atlassian, and Google verification strings, plus an SPF record.

The SPF string observed was: `v=spf1 include:_spf.google.com include:servers.mcsv.net include:amazonses.com -all`. This identifies listed email-sending mechanisms and ends with a hard-fail qualifier. This observation is not a complete email-security audit.

Limitation: the initial timeout reflects a failed query attempt, not evidence that TXT records do not exist.

6. Web Technology Identification (WhatWeb)

Command used: `whatweb https://owasp.org`

WhatWeb returned HTTP 200 OK and identified HTML5, Vercel as the HTTP server indicator, Next.js via the X-Powered-By header, the OWASP Foundation page title, and a locale cookie. The reported IP was 216.150.1.129.

The output also listed security-related response headers, including Strict-Transport-Security, Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, and Permissions-Policy.

Interpretation: WhatWeb reports visible technology fingerprints and response indicators. Fingerprints may be incomplete or affected by hosting/CDN layers; they do not confirm the complete server architecture.

7. HTTP Response Header Review

Command used: `curl -I https://owasp.org`

Observed header	Observed value / purpose
Status	HTTP/2 200 — successful response
Strict-Transport-Security	max-age=31536000; includeSubDomains; preload — requests browsers to enforce HTTPS for the specified period
Content-Security-Policy	Restricts permitted resource sources; includes object-src 'none' and frame-ancestors 'none'
X-Frame-Options	DENY — prevents framing by other pages
X-Content-Type-Options	nosniff — prevents MIME-type sniffing
Referrer-Policy	strict-origin-when-cross-origin
Permissions-Policy	Restricts selected browser features including camera, microphone, and geolocation
Cross-Origin policies	Cross-Origin-Opener-Policy and Cross-Origin-Resource-Policy were present
Server / framework indicators	Vercel and Next.js indicators were returned

Interpretation: multiple browser-facing controls were present in the response. Header presence alone does not establish that the full policy is correct or resistant to bypass; no bypass testing was performed.

8. Google Dorking / Public Index Review

Searches included `site:owasp.org` and `site:owasp.org filetype:pdf`. The user-observed results included an OWASP financial-statement audit report dated 27 February 2025 and other indexed PDF results.

Interpretation: search engines can expose documents intentionally or unintentionally indexed for public discovery. The presence of a financial statement is not, by itself, evidence of sensitive-data exposure or a vulnerability. This report

does not assert that the document was confidential.

9. Certificate Transparency Review

The crt.sh search for `%.owasp.org` displayed certificate entries associated with owasp.org and hostnames such as docs.owasp.org, admin.owasp.org, contact.owasp.org, and cloud.owasp.org. The screenshot showed certificate authorities including Let's Encrypt and Google Trust Services.

Interpretation: certificate-transparency records provide public historical/current certificate metadata and can help identify hostnames associated with a domain. A certificate record does not prove that a hostname is currently reachable, active, or vulnerable. The previously viewed general CA page was not treated as target-specific evidence.

10. Limitations and Scope Discipline

• Findings are based on the provided terminal output and screenshots from a single collection period.

• The default-resolver TXT query timed out; the explicit query to 1.1.1.1 later succeeded.

• Google indexing and certificate-transparency data are not guaranteed to be complete or current.

• WhatWeb and HTTP headers provide fingerprints and response metadata, not a full security audit.

• An experimental Nmap SYN scan reported port 21/tcp open and 999 filtered ports on 216.150.1.129. It is excluded from the formal passive-reconnaissance findings because active-scan authorization was not established. No FTP login or further service testing was performed.

11. Conclusion

The passive reconnaissance exercise collected useful public information about owasp.org, including registrar and nameserver details, A/NS/MX/TXT DNS records, technology fingerprints, HTTP security-related headers, indexed public documents, and certificate-transparency entries. The TXT lookup succeeded when a specific public resolver was used after an earlier timeout. The reviewed observations did not confirm a security vulnerability. Any further active testing would require explicit authorization and a clearly defined scope.

Appendix A — Evidence checklist

■ A1. WHOIS output screenshot

■ A2. dig A / default DNS output screenshot

■ A3. dig NS output screenshot

■ A4. dig MX output screenshot

■ A5. Initial TXT timeout screenshot

■ A6. Successful dig @1.1.1.1 TXT output (paste provided terminal output or attach screenshot)

■ A7. WhatWeb output screenshot / terminal output

■ A8. curl -I output screenshot / terminal output

■ A9. Google search results screenshot

■ A10. crt.sh search results screenshot

Attach the original screenshots in the same order where your instructor requires visual evidence. Keep each screenshot readable and caption it with the command/search that produced it. Do not label routine observations as vulnerabilities.

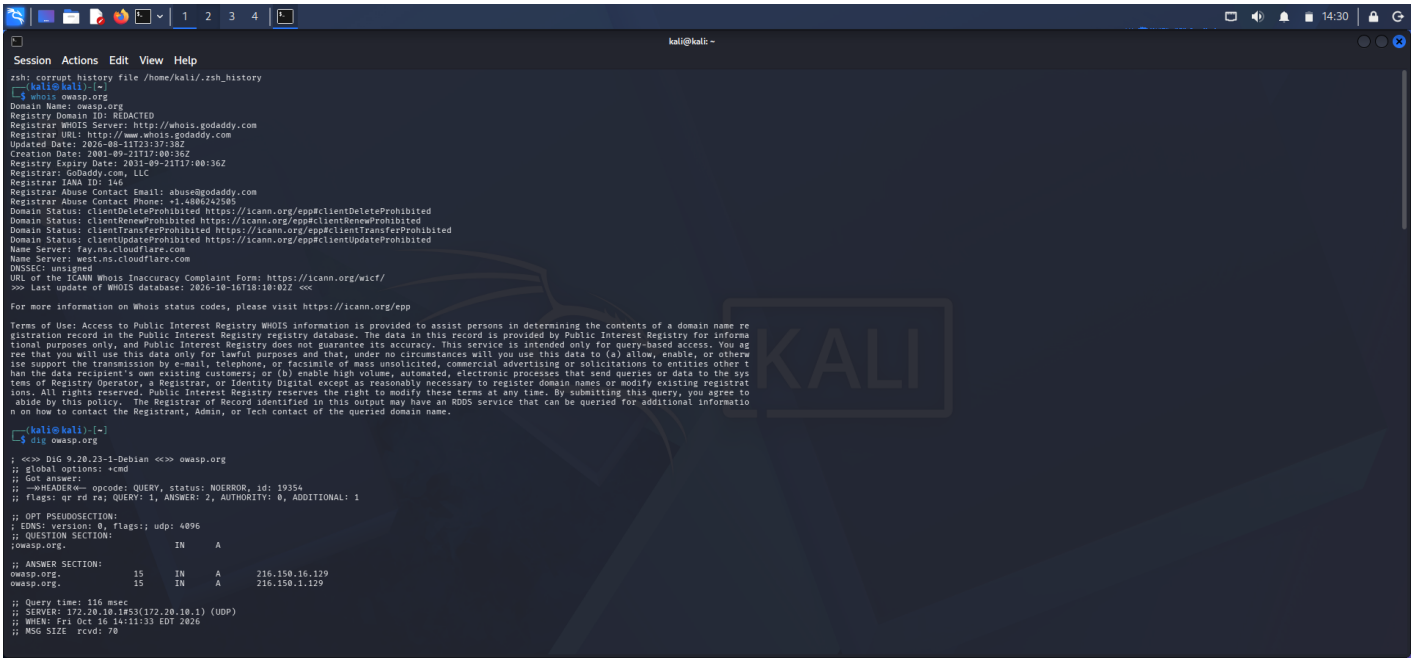
Appendix A — Evidence Screenshots

Screenshots supplied during the assignment workflow. Pasted text-only output is documented in the report but is not reproduced here as screenshot evidence.

> **Note:** Screenshots support observations; they do not establish a confirmed vulnerability.

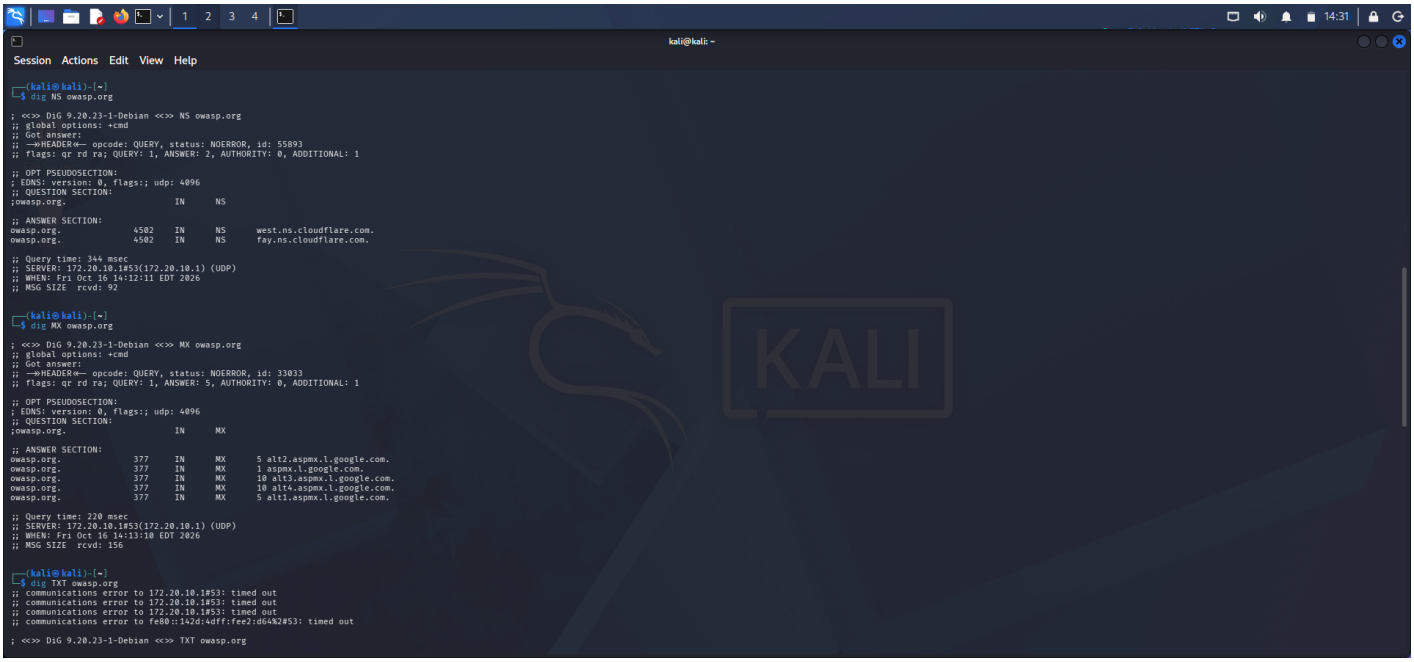
Evidence A1 — WHOIS and A-record lookup

WHOIS output and successful DNS A-record response.



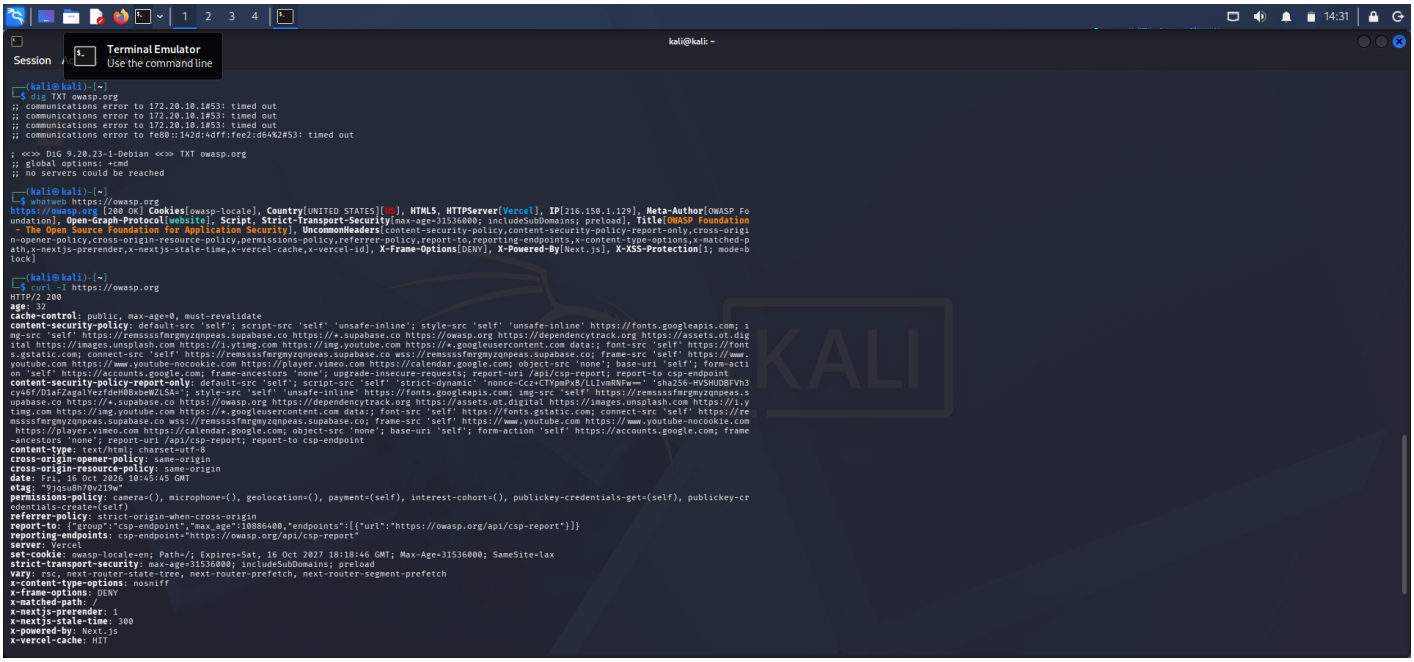
Evidence A2 — NS, MX, and initial TXT lookup

Nameserver and mail-server answers, followed by the initial TXT-query timeout.



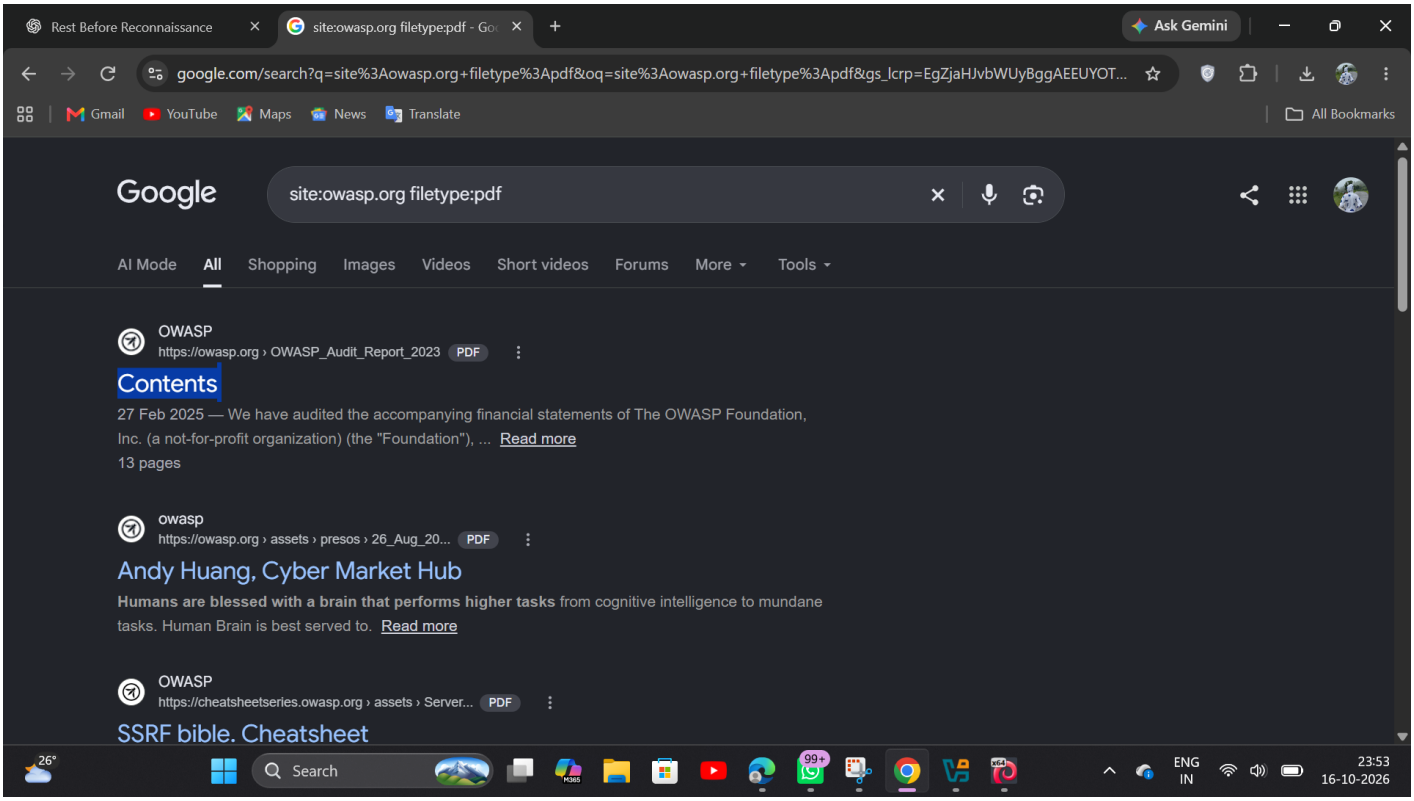
Evidence A3 — WhatWeb and HTTP response headers

WhatWeb technology indicators and curl -I response-header output.



Evidence A4 — Google indexed PDF results

Google results for site:owasp.org filetype:pdf.



Evidence A5 — Certificate transparency search

crt.sh results for %.owasp.org and related certificate entries.

